

Memoria de Práctica 7

Servidor de Correo Interno y Seguridad

Administración de Sistemas

20 de mayo de 2026

Resumen

En esta memoria se documenta el diseño, despliegue y configuración de un servidor de correo electrónico interno para el dominio de la empresa. El proyecto se basa en una arquitectura contenedorizada mediante Docker, utilizando Postfix como servidor SMTP para el envío y recepción de mensajes, y Dovecot como servidor IMAP para el acceso a los buzones. Adicionalmente, se integran políticas avanzadas de seguridad que incluyen el cifrado de las comunicaciones mediante STARTTLS y la prevención activa de abusos mediante el bloqueo de retransmisión abierta (Anti Open Relay).

Índice

1. Arquitectura y Servidor de Correo Interno	3
1.1. Descripción general	3
1.2. Arquitectura del contenedor	3
1.2.1. Imagen base y paquetes instalados	3
1.2.2. Estructura de ficheros copiados en la imagen	3
1.3. Configuración de Postfix	3
1.3.1. Identidad y dominio (<code>main.cf</code>)	3
1.3.2. Formato de buzones	4
1.3.3. Límites de tamaño y servicios	4
1.4. Configuración de Dovecot	4
1.4.1. Autenticación y Localización de buzones	4
1.4.2. Servicios y puertos (<code>10-master.conf</code>)	4
1.5. Script de arranque (<code>entrypoint.sh</code>)	4
2. Implementación y Pruebas del Servicio Base	5
2.1. Validación de Resolución DNS	5
2.2. Gestión de Usuarios y Buzones	6
2.3. Pruebas de Envío de Correo (SMTP)	6
2.4. Comprobación de Entrega (Maildir e IMAP)	8
2.5. Auditoría de Logs del Sistema	9
3. Bonus 1: Seguridad y Cifrado mediante STARTTLS	10
3.1. Fundamentos y Objetivos	10
3.2. Generación del Certificado Criptográfico	10
3.3. Configuración de Cifrado en Postfix y Dovecot	11
3.3.1. Cifrado SMTP (Postfix)	11
3.3.2. Cifrado IMAP (Dovecot)	11
3.4. Pruebas de Negociación y Auditoría de Conexión	11
4. Bonus 2: Prevención de Open Relay y Autenticación SASL	13
4.1. Contexto y Riesgos de Seguridad	13
4.2. Decisiones de Diseño y Configuración Anti-Relay	13
4.3. Auditoría y Evidencias de Ejecución	14
4.3.1. Prueba 1: Envío interno autorizado	14
4.3.2. Prueba 2: Intentos de Relay externo sin autenticar (Bloqueados) . .	14
4.3.3. Prueba 3: Relay externo autenticado mediante SASL (Permitido) . .	16

1. Arquitectura y Servidor de Correo Interno

1.1. Descripción general

Se ha desplegado un servidor de correo completo para el dominio `empresa.local` dentro de un contenedor Docker basado en **Ubuntu 22.04**. El servidor combina **Postfix** como agente de transferencia de correo (MTA) y **Dovecot** como servidor IMAP, ofreciendo un entorno de correo totalmente funcional y aislado de la red externa.

1.2. Arquitectura del contenedor

1.2.1. Imagen base y paquetes instalados

La imagen se construye a partir de `ubuntu:22.04` e instala los siguientes paquetes durante el proceso de *build*:

- **postfix** — MTA encargado del envío y entrega local de mensajes (SMTP, puerto 25).
- **dovecot-core / dovecot-imapd** — Servidor IMAP para la consulta de buzones (puerto 143).
- **rsyslog** — Démonio de *logging* necesario para generar `/var/log/mail.log` dentro del contenedor.
- **mailutils, swaks** — Herramientas de prueba para el envío y verificación de correos.
- **telnet, net-tools, dnsutils** — Utilidades de diagnóstico de red.

Los puertos expuestos son **25/tcp** (SMTP) y **143/tcp** (IMAP).

1.2.2. Estructura de ficheros copiados en la imagen

Fichero fuente	Destino en el contenedor
postfix/main.cf	/etc/postfix/main.cf
postfix/master.cf	/etc/postfix/master.cf
dovecot/dovecot.conf	/etc/dovecot/dovecot.conf
dovecot/10-auth.conf	/etc/dovecot/conf.d/
dovecot/10-mail.conf	/etc/dovecot/conf.d/
dovecot/10-master.conf	/etc/dovecot/conf.d/
dovecot/10-ssl.conf	/etc/dovecot/conf.d/
dovecot/15-mailboxes.conf	/etc/dovecot/conf.d/
ssl/mail.crt	/etc/ssl/certs/mail.crt
ssl/mail.key	/etc/ssl/private/mail.key
entrypoint.sh	/entrypoint.sh

Cuadro 1: Ficheros de configuración desplegados en el contenedor.

1.3. Configuración de Postfix

1.3.1. Identidad y dominio (main.cf)

El servidor se identifica como `mail.empresa.local` y acepta correo destinado al dominio `empresa.local`. Los parámetros principales son:

- `myhostname = mail.empresa.local`

- `mydomain = empresa.local`
- `mydestination` incluye el propio *hostname*, `localhost` y el dominio raíz.
- `inet_protocols = ipv4` — se deshabilita IPv6 para simplificar el entorno de laboratorio.

1.3.2. Formato de buzones

Se utiliza el formato **Maildir** (`home_mailbox = Maildir/`), compatible con Dovecot y con la estructura de directorios creada por el *entrypoint*: `~/Maildir/{new,cur,tmp}`.

1.3.3. Límites de tamaño y servicios

Se establecen límites de tamaño para mantener el rendimiento del servidor:

- Tamaño máximo de mensaje: **10 MB** (`message_size_limit = 10240000`).
- Tamaño máximo de buzón: **50 MB** (`mailbox_size_limit = 51200000`).

El fichero `master.cf` define los procesos internos de Postfix. El único servicio con escucha externa es `smtp inet` en el puerto 25.

1.4. Configuración de Dovecot

Dovecot sirve únicamente **IMAP** (`protocols = imap`) y redirige los logs a `/dev/stdout` para su visualización vía `docker logs`.

1.4.1. Autenticación y Localización de buzones

En el archivo `10-auth.conf` se permite la autenticación en texto plano (`disable_plaintext_auth = no`) para facilitar pruebas, habilitando los mecanismos **PLAIN** y **LOGIN**. La validación se realiza contra el sistema mediante el driver PAM. La ubicación de los buzones en `10-mail.conf` se define como:

```
1 mail_location = maildir:~/Maildir
2 mail_home      = /home/%u
```

1.4.2. Servicios y puertos (10-master.conf)

El proceso **imap-login** escucha en el puerto **143** admitiendo hasta 50 conexiones simultáneas. Además, el servicio `auth` expone un *Unix socket* en `/var/spool/postfix/private/auth` para que Postfix delegue la autenticación SASL en Dovecot.

1.5. Script de arranque (entrypoint.sh)

El *entrypoint* ejecuta de manera ordenada la inicialización del log (`rsyslogd`), la creación de las cuentas de usuario (`alice`, `bob`, `carlos`) con sus directorios Maildir, arranca Postfix y Dovecot, y mantiene la sesión activa siguiendo los logs con `tail -F /var/log/mail.log`.

2. Implementación y Pruebas del Servicio Base

Una vez descrita la arquitectura y los ficheros de configuración, se procede a validar el funcionamiento del servicio de correo en su estado base, confirmando la resolución de nombres, la gestión de usuarios y el flujo completo de envío y recepción.

2.1. Validación de Resolución DNS

Para que el correo fluya correctamente dentro de la red, los clientes y el propio servidor deben ser capaces de resolver el dominio. Se utiliza la herramienta `dig` contra el servidor DNS interno (172.20.0.10) para validar los tres registros esenciales:

```
symbiontz@DESKTOP-NIUV50S:/mnt/c/Users/symbiontz$ dig @172.20.0.10 mail.empresa.local A

; <<>> DiG 9.18.39-0ubuntu0.24.04.3-Ubuntu <<>> @172.20.0.10 mail.empresa.local A
; (1 server found)
; global options: +cmd
; Got answer:
; WARNING: .local is reserved for Multicast DNS
; You are currently testing what happens when an mDNS query is leaked to DNS
; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 22926
; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
; WARNING: recursion requested but not available

; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 81af1de1d6ad7c63010000006a04b512edb38328c2b987b6 (good)
; QUESTION SECTION:
;mail.empresa.local.                IN      A

; ANSWER SECTION:
mail.empresa.local.                86400   IN      A      172.20.0.50

; Query time: 3 msec
; SERVER: 172.20.0.10#53(172.20.0.10) (UDP)
; WHEN: Wed May 13 19:29:54 CEST 2026
; MSG SIZE rcvd: 91
```

Figura 1: Resolución del registro tipo A: mail.empresa.local apunta a 172.20.0.50.

```
symbiontz@DESKTOP-NIUV50S:/mnt/c/Users/symbiontz$ dig @172.20.0.10 empresa.local MX

; <<>> DiG 9.18.39-0ubuntu0.24.04.3-Ubuntu <<>> @172.20.0.10 empresa.local MX
; (1 server found)
; global options: +cmd
; Got answer:
; WARNING: .local is reserved for Multicast DNS
; You are currently testing what happens when an mDNS query is leaked to DNS
; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 63718
; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 2
; WARNING: recursion requested but not available

; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: bdb1ba48620655b9010000006a04b56dfeaadce70b3dad02 (good)
; QUESTION SECTION:
;empresa.local.                    IN      MX

; ANSWER SECTION:
empresa.local.                    86400   IN      MX      10 mail.empresa.local.

; ADDITIONAL SECTION:
mail.empresa.local.              86400   IN      A      172.20.0.50

; Query time: 3 msec
; SERVER: 172.20.0.10#53(172.20.0.10) (UDP)
; WHEN: Wed May 13 19:31:25 CEST 2026
; MSG SIZE rcvd: 107
```

Figura 2: Resolución del registro MX: El correo para empresa.local se delega a mail.empresa.local.

```

symbiontz@DESKTOP-NIUV50S:/mnt/c/Users/symbiontz$ dig @172.20.0.10 -x 172.20.0.50
; <<>> DiG 9.18.39-0ubuntu0.24.04.3-Ubuntu <<>> @172.20.0.10 -x 172.20.0.50
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 64984
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 1232
;; COOKIE: b65a56338cb76a3601000006a04b6d04cfa55c9779de7df (good)
;; QUESTION SECTION:
;50.0.20.172.in-addr.arpa.      IN      PTR

;; ANSWER SECTION:
50.0.20.172.in-addr.arpa. 86400 IN      PTR      mail.empresa.local.

;; Query time: 3 msec
;; SERVER: 172.20.0.10#53(172.20.0.10) (UDP)
;; WHEN: Wed May 13 19:37:20 CEST 2026
;; MSG SIZE rcvd: 113

```

Figura 3: Resolución inversa (PTR): La IP 172.20.0.50 resuelve de vuelta al *hostname* del servidor.

2.2. Gestión de Usuarios y Buzones

Los usuarios de correo en esta infraestructura son cuentas del propio sistema Linux. El script `entripoint.sh` ya crea usuarios por defecto, pero se demuestra el proceso de alta manual creando al usuario `fabio`. Se le asigna contraseña y se genera manualmente su estructura de directorios Maildir (`new`, `cur`, `tmp`) asignándole los permisos correspondientes:

```

symbiontz@DESKTOP-NIUV50S:/mnt/c/Users/symbiontz$ docker exec -it mail_server bash
root@mail:/# useradd -m -s /bin/bash fabio
root@mail:/# echo "fabio:fabio123!" | chpasswd
root@mail:/# mkdir -p /home/fabio/Maildir/{new,cur,tmp}
root@mail:/# chown -R fabio:fabio /home/fabio/Maildir
root@mail:/# exit
exit

```

Figura 4: Creación del usuario `fabio` y aprovisionamiento de su buzón Maildir mediante consola.

2.3. Pruebas de Envío de Correo (SMTP)

Para certificar que Postfix enruta los correos correctamente, se realizan pruebas de envío utilizando tres métodos distintos.

El primer método utiliza el comando nativo `mail` (del paquete `mailutils`) ejecutado desde dentro del propio contenedor, simulando envíos locales hacia `carlos`:

```

PS C:\Users\symbiontz> docker exec -it mail_server bash
root@mail:/# echo "Hola Carlos, como te trata la vida?." \
| mail -s "Prueba mail Fabio" \
-r "fabio@empresa.local" \
carlos@empresa.local
root@mail:/# # Enviar correo de bob a carlos
echo "Hola Carlos, mensaje de Bob." \
| mail -s "Saludo de Bob" \
-r "bob@empresa.local" \
carlos@empresa.local

```

Figura 5: Envío de correos internos utilizando el cliente de consola `mail`.

El segundo método emplea `swaks`, una herramienta especializada en transacciones

SMTP. Se simula un envío desde **alice** hacia **bob**. La salida muestra el diálogo SMTP completo, culminando con la aceptación del mensaje (250 2.0.0 Ok: queued):

```
root@mail:/# swaks \
--to bob@empresa.local \
--from alice@empresa.local \
--server 172.20.0.50 \
--port 25 \
--header "Subject: Test SMTP con swaks" \
--body "Mensaje de prueba enviado con swaks."
...
=== Trying 172.20.0.50:25...
=== Connected to 172.20.0.50.
<- 220 mail.empresa.local ESMTP Postfix
-> EHLO mail.empresa.local
<- 250-mail.empresa.local
<- 250-PIPELINING
<- 250-SIZE 10240000
<- 250-VRFY
<- 250-ETRN
<- 250-ENHANCEDSTATUSCODES
<- 250-8BITMIME
<- 250-DSN
<- 250 CHUNKING
-> MAIL FROM:<alice@empresa.local>
<- 250 2.1.0 Ok
-> RCPT TO:<bob@empresa.local>
<- 250 2.1.5 Ok
-> DATA
<- 354 End data with <CR><LF>.<CR><LF>
-> Date: Wed, 20 May 2026 14:20:33 +0000
-> To: bob@empresa.local
-> From: alice@empresa.local
-> Subject: Test SMTP con swaks
-> Message-Id: <20260520142033.000218@mail.empresa.local>
-> X-Mailer: swaks v20201014.0 jetmore.org/john/code/swaks/
->
-> Mensaje de prueba enviado con swaks.
->
-> .
<- 250 2.0.0 Ok: queued as F2F4413A01
-> QUIT
<- 221 2.0.0 Bye
=== Connection closed with remote host.
```

Figura 6: Transacción SMTP exitosa entre **alice** y **bob** utilizando la herramienta **swaks**.

El tercer método consiste en interactuar directamente con el demonio de Postfix a través de una sesión **telnet** por el puerto 25. Esto permite introducir los comandos SMTP (EHLO, MAIL FROM, RCPT TO, DATA) de forma totalmente manual:

```

root@mail:/# telnet 172.20.0.50 25
Trying 172.20.0.50...
Connected to 172.20.0.50.
Escape character is '^]'.
220 mail.empresa.local ESMTP Postfix
EHLO mail.empresa.local
250-mail.empresa.local
250-PIPELINING
250-SIZE 10240000
250-VRFY
250-ETRN
250-ENHANCEDSTATUSCODES
250-8BITMIME
250-DSN
250 CHUNKING
MAIL FROM:<carlos@empresa.local>
250 2.1.0 Ok
RCPT TO:<alice@empresa.local>
250 2.1.5 Ok
DATA
354 End data with <CR><LF>.<CR><LF>
Subject: Correo manual via telnet
From: carlos@empresa.local
To: alice@empresa.local
Hola Alice. Este mensaje fue enviado manualmente con telnet.
.
250 2.0.0 Ok: queued as 75D5AE09
QUIT
221 2.0.0 Bye
Connection closed by foreign host.

```

Figura 7: Envío manual de un correo desde carlos hacia alice dialogando vía telnet con el puerto 25.

2.4. Comprobación de Entrega (Maildir e IMAP)

Una vez enviados los correos, es vital confirmar que el servidor los ha entregado y que son legibles. Primero, se verifica la entrega a nivel de sistema de ficheros. Al explorar la carpeta Maildir/new/ del usuario bob, se observa el archivo generado. Al hacer `cat` sobre él, se visualiza el contenido exacto del correo enviado previamente con `swaks`:

```

PS C:\Users\symbiontz> docker exec mail_server ls -la /home/bob/Maildir/new/
total 12
drwxr-xr-x 2 bob bob 4096 May 20 14:20 .
drwxr-xr-x 5 bob bob 4096 May 13 17:55 ..
-rw----- 1 bob bob 558 May 20 14:20 1779286833.V82I13a05M998785.mail.empresa.local
PS C:\Users\symbiontz> docker exec mail_server cat /home/bob/Maildir/new/1779286833.V82I13a05M998785.mail.empresa.local
Return-Path: <alice@empresa.local>
X-Original-To: bob@empresa.local
Delivered-To: bob@empresa.local
Received: from mail.empresa.local (mail.empresa.local [172.20.0.50])
  by mail.empresa.local (Postfix) with ESMTP id F2F4413A01
  for <bob@empresa.local>; Wed, 20 May 2026 14:20:33 +0000 (UTC)
Date: Wed, 20 May 2026 14:20:33 +0000
To: bob@empresa.local
From: alice@empresa.local
Subject: Test SMTP con swaks
Message-Id: <20260520142033.000218@mail.empresa.local>
X-Mailer: swaks v20201014.0 jetmore.org/john/code/swaks/
Mensaje de prueba enviado con swaks.

```

Figura 8: Inspección directa del buzón Maildir de bob confirmando la entrega física del mensaje en disco.

Por otro lado, se valida el funcionamiento del servidor Dovecot interactuando con el protocolo IMAP en el puerto 143 vía `telnet`. Se inicia sesión con las credenciales de `alice`, se selecciona la bandeja de entrada (`SELECT INBOX`) y se solicita el cuerpo del primer mensaje (`FETCH 1 (BODY[TEXT])`). La salida muestra el texto enviado anteriormente por carlos:


```

root@mail:/# telnet 172.20.0.50 143
Trying 172.20.0.50...
Connected to 172.20.0.50.
Escape character is '^'.
* OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE LITERAL+ STARTTLS A
a1 LOGIN Alice Alice123!
a1 OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE SORT SORT=DISPLAY
NAMESPACE UIDPLUS LIST-EXTENDED I18NLEVEL=1 CONDSTORE QRESYNC ESEARCH ESORT SEARCHRES
LITERAL+ NOTIFY SPECIAL-USE] Logged in
a2 LIST "" "*"
* LIST (\HasNoChildren \Drafts) "/" Drafts
* LIST (\HasNoChildren \Junk) "/" Junk
* LIST (\HasNoChildren \Sent) "/" Sent
* LIST (\HasNoChildren \Trash) "/" Trash
* LIST (\HasNoChildren) "/" INBOX
a2 OK List completed (0.007 + 0.000 + 0.006 secs).
a3 SELECT INBOX
* FLAGS (\Answered \Flagged \Deleted \Seen \Draft)
* OK [PERMANENTFLAGS (\Answered \Flagged \Deleted \Seen \Draft \*)] Flags permitted.
* 1 EXISTS
* 1 RECENT
* OK [UNSEEN 1] First unseen.
* OK [UIDVALIDITY 1779287424] UIDs valid
* OK [UIDNEXT 2] Predicted next UID
a3 OK [READ-WRITE] Select completed (0.004 + 0.000 + 0.003 secs).
a4 STATUS INBOX (MESSAGES UNSEEN RECENT)
* STATUS INBOX (MESSAGES 1 RECENT 1 UNSEEN 1)
a4 OK [CLIENTBUG] Status on selected mailbox completed (0.001 + 0.000 secs).
a5 FETCH 1 (BODY[HEADER])
* 1 FETCH (FLAGS (\Seen \Recent) BODY[HEADER] {495}
Return-Path: <carlos@empresa.local>
X-Original-To: alice@empresa.local
Delivered-To: alice@empresa.local
Received: from mail.empresa.local (mail.empresa.local [172.20.0.50])
    by mail.empresa.local (Postfix) with ESMTP id 75D5AE09
    for <alice@empresa.local>; Wed, 20 May 2026 14:23:10 +0000 (UTC)
Subject: Correo manual via telnet
From: carlos@empresa.local
To: alice@empresa.local
Message-Id: <20260520142317.75D5AE09@mail.empresa.local>
Date: Wed, 20 May 2026 14:23:10 +0000 (UTC)
)
a5 OK Fetch completed (0.002 + 0.000 + 0.001 secs).
a6 FETCH 1 (BODY[TEXT])
* 1 FETCH (BODY[TEXT] {62}
Hola Alice. Este mensaje fue enviado manualmente con telnet.
)
a6 OK Fetch completed (0.002 + 0.000 + 0.001 secs).

```

Figura 9: Consulta y lectura de correos vía IMAP interactuando manualmente con Dovecot.

2.5. Auditoría de Logs del Sistema

Por último, para confirmar que todos los procesos internos (pickup, cleanup, qmgr y local) han actuado correctamente sin generar advertencias, se revisa la salida en tiempo real del archivo de registro `/var/log/mail.log`:

```

PS C:\Users\symbiontz> docker exec mail_server tail -F /var/log/mail.log
May 20 14:42:01 mail postfix[60]: Postfix is running with backwards-compatible default settings
May 20 14:42:01 mail postfix[60]: See http://www.postfix.org/COMPATIBILITY_README.html for details
May 20 14:42:01 mail postfix[60]: To disable backwards compatibility use "postconf compatibility_level=3.6" and "postfix reload"
May 20 14:42:02 mail postfix[169]: Postfix is running with backwards-compatible default settings
May 20 14:42:02 mail postfix[169]: See http://www.postfix.org/COMPATIBILITY_README.html for details
May 20 14:42:02 mail postfix[169]: To disable backwards compatibility use "postconf compatibility_level=3.6" and "postfix reload"
May 20 14:42:02 mail postfix/postfix-script[245]: starting the Postfix mail system
May 20 14:42:02 mail postfix/master[247]: daemon started -- version 3.6.4, configuration /etc/postfix
May 20 14:46:10 mail postfix/pickup[248]: BBDFD3C1AD: uid=0 from=<alice@empresa.local>
May 20 14:46:10 mail postfix/cleanup[286]: BBDFD3C1AD: message-id=<20260520144610.BBDFD3C1AD@mail.empresa.local>
May 20 14:46:10 mail postfix/qmgr[249]: BBDFD3C1AD: from=<alice@empresa.local>, size=343, nrcpt=1 (queue active)
May 20 14:46:10 mail postfix/local[288]: BBDFD3C1AD: to=<bob@empresa.local>, relay=local, delay=0.03, delays=0.02/0.01/0/0, dsn=2.0.0, status=sent (delivered to maildir)
May 20 14:46:10 mail postfix/qmgr[249]: BBDFD3C1AD: removed
May 20 14:46:54 mail postfix/pickup[248]: 18EF83C1C8: uid=0 from=<bob@empresa.local>
May 20 14:46:54 mail postfix/cleanup[286]: 18EF83C1C8: message-id=<20260520144654.18EF83C1C8@mail.empresa.local>
May 20 14:46:54 mail postfix/qmgr[249]: 18EF83C1C8: from=<bob@empresa.local>, size=353, nrcpt=1 (queue active)
May 20 14:46:54 mail postfix/local[288]: 18EF83C1C8: to=<alice@empresa.local>, relay=local, delay=0.01, delays=0.01/0/0/0, dsn=2.0.0, status=sent (delivered to maildir)
May 20 14:46:54 mail postfix/qmgr[249]: 18EF83C1C8: removed

```

Figura 10: Revisión del log `mail.log` mostrando el ciclo de vida completo de la encolación y entrega final a Maildir.

3. Bonus 1: Seguridad y Cifrado mediante STARTTLS

3.1. Fundamentos y Objetivos

En su configuración por defecto, los protocolos SMTP (puerto 25) e IMAP (puerto 143) transmiten la información en texto plano. Esto supone un grave riesgo de seguridad, ya que tanto las credenciales de autenticación de los usuarios como el contenido de los propios mensajes podrían ser interceptados mediante ataques de intermediario (*Man-in-the-Middle* o *sniffing* de red).

Para mitigar esta vulnerabilidad sin necesidad de abrir puertos adicionales exclusivos para SSL/TLS (como el 465 o el 993), la empresa requiere la implementación de la extensión **STARTTLS**. Este mecanismo permite a los clientes y servidores negociar una actualización de la conexión: la comunicación comienza en texto plano y, mediante el comando STARTTLS, se eleva dinámicamente a una sesión cifrada antes de intercambiar cualquier dato sensible.

3.2. Generación del Certificado Criptográfico

El primer paso para habilitar el cifrado es dotar al servidor de un par de claves criptográficas. Al tratarse de un entorno de laboratorio interno, se opta por generar un certificado autofirmado (Self-Signed Certificate) utilizando la suite de herramientas **openssl**.

Se genera una clave privada RSA de 2048 bits y su correspondiente certificado X.509 con una validez temporal. El campo *Common Name* (CN) se configura explícitamente para que coincida con el dominio del servidor: **mail.empresa.local**. Mediante el comando **openssl x509**, se puede inspeccionar la estructura del certificado resultante, verificando el algoritmo de firma (SHA256 con cifrado RSA) y los datos del emisor:

```
jaime@minty:~/AS-2025$ openssl x509 -in stacks/services/mail/ssl/mail.crt -text -noout
Certificate:
  Data:
    Version: 3 (0x2)
    Serial Number:
      78:c0:57:22:fd:42:f8:b2:b1:fc:3d:6d:dc:b8:05:21:23:88:ef:04
    Signature Algorithm: sha256WithRSAEncryption
    Issuer: C = ES, ST = Madrid, L = Madrid, O = Empresa, OU = IT, CN = mail.empresa.local
    Validity
      Not Before: May 14 09:07:15 2026 GMT
      Not After : May 14 09:07:15 2027 GMT
    Subject: C = ES, ST = Madrid, L = Madrid, O = Empresa, OU = IT, CN = mail.empresa.local
    Subject Public Key Info:
      Public Key Algorithm: rsaEncryption
      Public-Key: (2048 bit)
      Modulus:
        00:b9:55:2f:55:fe:ab:b4:e7:1d:2f:af:25:ba:55:
        6f:73:fd:3b:b2:6a:b7:59:2e:b7:95:de:93:2d:f4:
        ac:98:a6:90:92:bc:f6:fc:30:62:64:89:ee:6d:04:
        3d:68:19:ee:38:b4:2b:3a:71:ca:3f:a7:49:77:55:
        e1:c0:d9:f6:48:5d:57:10:cf:c1:bb:f0:b5:c6:2e:
        94:db:62:46:a3:ca:91:f4:c5:3c:f6:1e:03:bc:b2:
        4b:00:60:8f:a8:29:14:89:b2:26:4a:1b:2c:6f:ca:
        b8:d7:5c:ae:fe:d7:d8:2b:54:41:ac:74:4c:b4:9e:
        92:e5:aa:97:12:b3:31:e8:af:55:25:d8:52:ad:d3:
        fb:db:d6:97:b6:59:cc:5e:e2:0e:17:ff:81:7a:ea:
        c6:50:51:b2:38:cf:72:64:08:df:00:8a:2e:29:4a:
        5d:25:0d:a4:30:5a:81:81:41:3c:39:b5:14:0d:a1:
        b7:86:f3:6c:b3:d4:b6:9d:2b:7b:ab:d6:38:36:52:
        65:cd:2a:9c:9a:94:9d:11:52:d0:ae:09:94:18:73:
        53:99:02:65:8c:dd:fa:48:62:1b:52:fa:e8:5d:41:
        9e:ef:d5:6b:e7:86:3c:ff:2c:f7:b0:32:6d:ea:42:
        53:80:0a:41:16:45:eb:b4:52:00:4b:27:9d:20:1f:
        fe:25
      Exponent: 65537 (0x10001)
    X509v3 extensions:
      X509v3 Subject Key Identifier:
        8C:AC:95:B8:59:CA:80:C6:3A:A5:62:DE:B1:B9:72:CC:6E:73:54:F2
      X509v3 Authority Key Identifier:
```

Figura 11: Información detallada del certificado autofirmado utilizando **openssl x509**.

Estos archivos (`mail.crt` y `mail.key`) se almacenan en los directorios estándar `/etc/ssl/certs/` y `/etc/ssl/private/` dentro del contenedor, asegurando que los permisos de lectura sean restrictivos.

3.3. Configuración de Cifrado en Postfix y Dovecot

Una vez disponibles los certificados, es necesario instruir a los servicios para que los utilicen.

3.3.1. Cifrado SMTP (Postfix)

En el fichero principal de configuración de Postfix (`main.cf`), se incorporan las directivas necesarias para habilitar el soporte TLS. Se utiliza el modo *opportunistic TLS* mediante la directiva `smtpd_tls_security_level = may`. Esto significa que Postfix anunciará el soporte de STARTTLS a los clientes; si el cliente lo soporta, la conexión se cifrará, pero si no, se permitirá la conexión en texto plano (necesario para compatibilidad en ciertos entornos internos).

Se verifica la correcta aplicación de estos parámetros solicitando a Postfix que muestre su configuración activa de TLS mediante el comando `postconf`:

```
jaime@minty:~/AS-2025$ docker exec mail_server postconf -n | grep tls
smtp_tls_loglevel = 0
smtp_tls_security_level = may
smtpd_tls_cert_file = /etc/ssl/certs/mail.crt
smtpd_tls_key_file = /etc/ssl/private/mail.key
smtpd_tls_security_level = may
smtpd_use_tls = yes
```

Figura 12: Verificación de los parámetros TLS en Postfix mediante `postconf`.

3.3.2. Cifrado IMAP (Dovecot)

Por su parte, el servicio de acceso a buzones requiere una configuración análoga en el fichero `10-ssl.conf`. Se establece el parámetro `ssl = yes` (que habilita el soporte de STARTTLS de forma obligatoria o mixta dependiendo de la configuración de texto plano) y se referencian las rutas absolutas del certificado y la clave. El comando `doveconf` permite confirmar que Dovecot ha cargado correctamente estas rutas en memoria:

```
jaime@minty:~/AS-2025$ docker exec mail_server doveconf -n | grep ssl
ssl_cert = </etc/ssl/certs/mail.crt
ssl_client_ca_dir = /etc/ssl/certs
ssl_key = # hidden, use -P to show it
```

Figura 13: Verificación de las rutas del certificado y clave en Dovecot mediante `doveconf`.

3.4. Pruebas de Negociación y Auditoría de Conexión

Para auditar la configuración y garantizar que el cifrado se aplica de manera efectiva en la capa de red, se recurre a la herramienta `s_client` de OpenSSL, la cual permite interactuar directamente con los puertos simulando ser un cliente de correo.

En primer lugar, se lanza una petición de conexión contra el puerto 25 de Postfix exigiendo la inicialización del protocolo SMTP seguro (`-starttls smtp`). La salida del comando confirma un *handshake* exitoso:

```

jaime@minty:~/AS-2025/stacks/services$ openssl s_client -connect localhost:25 -starttls smtp -brief
Can't use SSL_get_servername
depth=0 C = ES, ST = Madrid, L = Madrid, O = Empresa, OU = IT, CN = mail.empresa.local
verify error:num=18:self-signed certificate
CONNECTION ESTABLISHED
Protocol version: TLSv1.3
Ciphersuite: TLS_AES_256_GCM_SHA384
Peer certificate: C = ES, ST = Madrid, L = Madrid, O = Empresa, OU = IT, CN = mail.empresa.local
Hash used: SHA256
Signature type: RSA-PSS
Verification error: self-signed certificate
Server Temp Key: X25519, 253 bits
250 CHUNKING

```

Figura 14: Conexión cifrada a Postfix (SMTP) mediante STARTTLS. Se observa el uso de TLSv1.3.

Se puede observar en la captura que el servidor negocia utilizando **TLSv1.3** y la suite de cifrado robusta **TLS_AES_256_GCM_SHA384**. Como es esperable en entornos de desarrollo, OpenSSL advierte de un error de verificación (*self-signed certificate*), lo cual es un comportamiento normal ya que el certificado no está firmado por una Autoridad Certificadora (CA) pública, pero no impide que el canal de comunicación esté completamente encriptado.

Se repite la misma batería de pruebas contra el puerto 143 de Dovecot (**-starttls imap**):

```

jaime@minty:~/AS-2025/stacks/services$ openssl s_client -connect localhost:143 -starttls imap -brief
Can't use SSL_get_servername
depth=0 C = ES, ST = Madrid, L = Madrid, O = Empresa, OU = IT, CN = mail.empresa.local
verify error:num=18:self-signed certificate
CONNECTION ESTABLISHED
Protocol version: TLSv1.3
Ciphersuite: TLS_AES_256_GCM_SHA384
Peer certificate: C = ES, ST = Madrid, L = Madrid, O = Empresa, OU = IT, CN = mail.empresa.local
Hash used: SHA256
Signature type: RSA-PSS
Verification error: self-signed certificate
Server Temp Key: X25519, 253 bits
. OK Pre-login capabilities listed, post-login capabilities have more.

```

Figura 15: Conexión cifrada a Dovecot (IMAP) confirmando la suite de cifrado y el certificado del servidor.

El resultado es idéntico: el servicio IMAP responde al saludo inicial, actualiza la conexión a TLSv1.3 y expone de forma segura las capacidades de inicio de sesión (*capabilities*) al cliente, demostrando que la vulnerabilidad de interceptación de tráfico ha quedado totalmente resuelta.

4. Bonus 2: Prevención de Open Relay y Autenticación SASL

4.1. Contexto y Riesgos de Seguridad

Una de las vulnerabilidades más críticas en la administración de sistemas de correo es la configuración de un servidor como *Open Relay* (retransmisión abierta). Esto sucede cuando el Agente de Transferencia de Correo (MTA) acepta enviar mensajes hacia dominios externos provenientes de usuarios o direcciones IP que no son de confianza y que no se han autenticado previamente. El principal riesgo de esta mala práctica es que el servidor termine siendo explotado por *bots* para el envío masivo de *spam*, lo que provoca su inclusión casi inmediata en listas negras globales (*blacklists*).

4.2. Decisiones de Diseño y Configuración Anti-Relay

Para cumplir con los requisitos estipulados por la empresa (permitir el tráfico interno, bloquear los intentos externos no autenticados y autorizar a los usuarios remotos con credenciales válidas), se opta por implementar **Autenticación SASL** delegando la validación en **Dovecot**.

En el archivo de configuración principal de Postfix (`/etc/postfix/main.cf`), se define el comportamiento del servidor ante las peticiones de retransmisión. Se configuran las redes de confianza y se establece una jerarquía estricta de restricciones en la directiva `smtpd_relay_restrictions`:

```
# — Relay: SÓLO red interna (anti-relay abierto) —————
mynetworks = 127.0.0.0/8, 172.20.0.0/24
relayhost =

# Autenticación SASL mediante Dovecot
smtpd_sasl_auth_enable = yes
smtpd_sasl_type = dovecot
smtpd_sasl_path = private/auth
smtpd_sasl_security_options = noanonymous

# Rechazar relay para orígenes externos, pero permitir autenticados
smtpd_relay_restrictions =
    permit_mynetworks,
    permit_sasl_authenticated,
    reject_unauth_destination
```

Figura 16: Configuración de redes de confianza, parámetros SASL y restricciones de Relay en Postfix.

El funcionamiento de estas reglas obedece a la siguiente lógica secuencial:

1. `permit_mynetworks`: Autoriza libremente el relay a cualquier equipo cuya IP origen coincida con las redes locales definidas (127.0.0.0/8 y 172.20.0.0/24).
2. `permit_sasl_authenticated`: Permite realizar envíos hacia dominios externos a cualquier usuario que se autentique correctamente, validando sus credenciales contra el *socket* de Dovecot configurado en `private/auth`.
3. `reject_unauth_destination`: Funciona como regla por defecto (*catch-all*). Rechaza tajantemente cualquier correo cuyo destino no sea el propio dominio local si no se ha cumplido ninguna de las dos condiciones anteriores.

4.3. Auditoría y Evidencias de Ejecución

Para validar la solidez de esta configuración, se ejecuta una batería de pruebas utilizando la herramienta de diagnóstico **swaks**, cubriendo los diferentes escenarios de enrutamiento.

4.3.1. Prueba 1: Envío interno autorizado

En el primer escenario, se verifica que el enrutamiento interno funciona sin requerir autenticación adicional, dado que la IP del contenedor pertenece a una red de confianza. El usuario **bob** envía un correo a **alice** de forma exitosa, siendo encolado por el servidor con el código 250 2.0.0 Ok:

```
PS C:\Users\symbiontz> docker exec -it mail_server bash
root@mail:/# swaks \
  --to alice@empresa.local \
  --from bob@empresa.local \
  --server 172.20.0.50 \
  --port 25
...
=== Trying 172.20.0.50:25...
=== Connected to 172.20.0.50.
<- 220 mail.empresa.local ESMTP Postfix
-> EHLO mail.empresa.local
<- 250-mail.empresa.local
<- 250-PIPELINING
<- 250-SIZE 10240000
<- 250-VRFY
<- 250-ETRN
<- 250-STARTTLS
<- 250-ENHANCEDSTATUSCODES
<- 250-8BITMIME
<- 250-DSN
<- 250 CHUNKING
-> MAIL FROM:<bob@empresa.local>
<- 250 2.1.0 Ok
-> RCPT TO:<alice@empresa.local>
<- 250 2.1.5 Ok
-> DATA
<- 354 End data with <CR><LF>.<CR><LF>
-> Date: Wed, 20 May 2026 14:52:39 +0000
-> To: alice@empresa.local
-> From: bob@empresa.local
-> Subject: test Wed, 20 May 2026 14:52:39 +0000
-> Message-Id: <20260520145239.000319@mail.empresa.local>
-> X-Mailer: swaks v20201014.0 jetmore.org/john/code/swaks/
->
-> This is a test mailing
->
-> .
<- 250 2.0.0 Ok: queued as 6A36F3C1D7
-> QUIT
<- 221 2.0.0 Bye
=== Connection closed with remote host.
```

Figura 17: Prueba exitosa de enrutamiento interno sin autenticación (bob hacia alice).

4.3.2. Prueba 2: Intentos de Relay externo sin autenticar (Bloqueados)

A continuación, se simula el comportamiento de un usuario local (**alice**) que intenta enviar un correo hacia un dominio externo (**test@gmail.com**) omitiendo el paso de auten-

ticación. Postfix aplica la regla `reject_unauth_destination`, bloqueando la petición con el error 554 5.7.1 Relay access denied:

```
root@mail:/# swaks \
  --to test@gmail.com \
  --from alice@empresa.local \
  --server 172.20.0.50 \
  --port 25
...

=== Trying 172.20.0.50:25...
=== Connected to 172.20.0.50.
<- 220 mail.empresa.local ESMTP Postfix
-> EHLO mail.empresa.local
<- 250-mail.empresa.local
<- 250-PIPELINING
<- 250-SIZE 10240000
<- 250-VERFY
<- 250-ETRN
<- 250-STARTTLS
<- 250-ENHANCEDSTATUSCODES
<- 250-8BITMIME
<- 250-DSN
<- 250 CHUNKING
-> MAIL FROM:<alice@empresa.local>
<- 250 2.1.0 Ok
-> RCPT TO:<test@gmail.com>
< ** 554 5.7.1 <test@gmail.com>: Relay access denied
-> QUIT
<- 221 2.0.0 Bye
=== Connection closed with remote host.
```

Figura 18: Bloqueo de reenvío hacia un dominio externo sin credenciales (Primer intento).

Para confirmar la consistencia del bloqueo y simular un ataque desde el exterior, se realiza un envío simulando ser un usuario externo (`hacker@externo.com`) hacia un destino que tampoco pertenece al dominio (`test@gmail.com`). Como era de esperar, la conexión es rechazada por Postfix con el mismo error:

```

symbiontz@DESKTOP-NIUV50S:/mnt/c/Users/symbiontz$ swaks \
--to test@gmail.com \
--from hacker@externo.com \
--server localhost \
--port 25
...
=== Trying localhost:25...
=== Connected to localhost.
<- 220 mail.empresa.local ESMTP Postfix
-> EHLO DESKTOP-NIUV50S.localdomain
<- 250-mail.empresa.local
<- 250-PIPELINING
<- 250-SIZE 10240000
<- 250-VERFY
<- 250-ETRN
<- 250-STARTTLS
<- 250-ENHANCEDSTATUSCODES
<- 250-8BITMIME
<- 250-DSN
<- 250 CHUNKING
-> MAIL FROM:<hacker@externo.com>
<- 250 2.1.0 Ok
-> RCPT TO:<test@gmail.com>
< ** 554 5.7.1 <test@gmail.com>: Relay access denied
-> QUIT
<- 221 2.0.0 Bye
=== Connection closed with remote host.

```

Figura 19: Verificación de bloqueo al intentar hacer relay simulando ser un origen externo.

4.3.3. Prueba 3: Relay externo autenticado mediante SASL (Permitido)

Por último, se demuestra la efectividad de la integración con Dovecot. El usuario `alice` repite el intento de enviar un correo hacia el exterior (`test@gmail.com`), pero esta vez proporciona sus credenciales legítimas mediante los parámetros `--auth LOGIN --auth-user alice --auth-password .^alice123!`.

El servidor procesa el usuario y la contraseña en formato codificado en base64 (como se observa en las respuestas `YWxpY2U=` y `QWxpY2UxMjMh`). Al ser validadas correctamente, Postfix responde con el código `235 2.7.0 Authentication successful`. Acto seguido, la regla `permit_sasl_authenticated` autoriza el reenvío, encolando el mensaje (`queued` as `BA14A3C184`) para su distribución exterior:


```

root@mail:/# swaks --to test@gmail.com --from alice@empresa.local \
--server 172.20.0.50 --port 25 \
--auth LOGIN --auth-user alice --auth-password "Alice123!"
=== Trying 172.20.0.50:25...
=== Connected to 172.20.0.50.
<- 220 mail.empresa.local ESMTF Postfix
-> EHLO mail.empresa.local
<- 250-mail.empresa.local
<- 250-PIPELINING
<- 250-SIZE 10240000
<- 250-VERFY
<- 250-ETRN
<- 250-STARTTLS
<- 250-AUTH PLAIN LOGIN
<- 250-ENHANCEDSTATUSCODES
<- 250-8BITMIME
<- 250-DSN
<- 250 CHUNKING
-> AUTH LOGIN
<- 334 VXNlcm5hbWU6
-> YWxpY2U=
<- 334 UGFzc3dvcmQ6
-> QWxpY2UxMjMh
<- 235 2.7.0 Authentication successful
-> MAIL FROM:<alice@empresa.local>
<- 250 2.1.0 Ok
-> RCPT TO:<test@gmail.com>
<- 250 2.1.5 Ok
-> DATA
<- 354 End data with <CR><LF>.<CR><LF>
-> Date: Wed, 20 May 2026 15:24:34 +0000
-> To: test@gmail.com
-> From: alice@empresa.local
-> Subject: test Wed, 20 May 2026 15:24:34 +0000
-> Message-Id: <20260520152434.000261@mail.empresa.local>
-> X-Mailer: swaks v20201014.0 jetmore.org/john/code/swaks/
->
-> This is a test mailing
->
->
-> .
<- 250 2.0.0 Ok: queued as BA14A3C184
-> QUIT
<- 221 2.0.0 Bye
=== Connection closed with remote host.

```

Figura 20: Prueba exitosa de envío externo demostrando el funcionamiento de la autenticación SASL con el usuario alice.

Esta serie de comprobaciones certifica empíricamente que el servidor se encuentra totalmente securizado frente a abusos, garantizando la operatividad exclusiva a los miembros legitimados de la empresa.